Clarionyx

FINAL PROJECT REPORT

Regulatory Compliance Intelligence Copilot

Grounded Multi-Framework RAG for GDPR, HIPAA, and NIST with Audit Logging and Human Review Support

Executive Summary

This report documents the final implemented version of the Regulatory Compliance Intelligence Assistant — a production-grade, evidence-grounded Question & Answer system for GDPR, HIPAA, and NIST compliance. The system employs Retrieval-Augmented Generation (RAG) to retrieve verified regulatory evidence from a Pinecone vector store, rerank it using Cohere, and generate grounded answers with OpenAI. All interactions are logged to Airtable for auditability, confidence-based routing escalates uncertain cases to human review, and the full validated KPI suite demonstrates readiness for academic and pilot deployment.

Project Title	Regulatory Compliance Q&A System for Healthcare
Project Number	Project 3 — Talent Sprint Capstone 2026
Programme	Applied Generative AI and Agentic AI
Submission Date	April 15, 2026
Created By	Raju Kumar

1. Project Objective and Scope

The project objective was to build a practical compliance assistant that answers regulatory questions with grounded source evidence rather than free-form chatbot responses. The system supports GDPR, HIPAA, and NIST frameworks. The final scope encompassed the complete pipeline: document ingestion and chunking, vector embedding and storage, semantic retrieval, evidence reranking, grounded answer generation, citation normalisation, confidence scoring, review routing, audit logging, and reviewed-answer retrieval. The authoritative review action is performed through Telegram.

2. Problem Statement

Compliance, privacy, and information-security teams in regulated organisations repeatedly answer the similar questions on GDPR, HIPAA, and NIST. Traditional approaches rely on manual interpretation of lengthy regulations, which slows response time, creates inconsistency, and weakens auditability. A generic chatbot is not acceptable in this context because unsupported answers create legal and operational risk.

This project addresses the problem by building a regulatory Q&A system that:

- Retrieves evidence from approved, authoritative source documents
- Generates grounded answers with normalised citations
- Applies a confidence-based routing rule to separate high-certainty self-service answers from cases requiring human review
- Escalates low-confidence cases to a human compliance officer before finalisation
- Maintains a full audit trail in Airtable for every interaction

3. Background and Domain Overview

3.1 Domain Overview

The project sits at the intersection of healthcare compliance, data privacy, and information security. GDPR governs personal data handling within the European Union. HIPAA governs protected health information (PHI) in the US healthcare context. NIST provides structured cybersecurity controls and guidance applicable across sectors. Employees typically need short, practical answers, but source material is long, cross-referenced, and difficult to interpret without specialist knowledge.

3.2 Problem Analysis

- Regulatory documents are dense and difficult for non-specialists to navigate quickly
- Manual answers are hard to standardise and difficult to audit retrospectively
- Incorrect guidance can lead to regulatory violations, financial penalties, and reputational harm
- A compliance assistant must be evidence-based, traceable, and capable of deferring uncertain cases to human review
- Existing generic chatbot solutions do not satisfy enterprise compliance auditability requirements

3.3 Potential Applications

- Healthcare organisations: HIPAA definitions, privacy obligations, breach notification, and data-handling questions
- Data privacy teams: GDPR consent, transparency, lawful basis, and individual rights queries
- Security and governance teams: NIST-aligned questions on controls and risk posture
- Internal self-service compliance support with an auditable, versioned answer trail
- Relevant Industry: Healthcare, Lifescience companies like Clinical research Organisation, Pharma, any other institutes or organisation handling personal data in Europe.

4. Motivation for Project Selection

This project was selected for the following strategic and technical reasons:

- High real-world impact: Compliance violations carry existential risk for organisations. A validated Q&A system directly reduces that risk by providing consistent, auditable answers.
- Advanced RAG engineering: The project demands sophisticated retrieval techniques like semantic chunking, multi-query expansion, reranking, and confidence scoring covering the most complex components of the programme curriculum.
- LLMOps integration: The Airtable-based validation workflow and version-tracked answer history represent a production-grade LLMOps pattern directly applicable to enterprise deployments.
- Rich public dataset availability: All primary regulatory texts (GDPR, HIPAA, NIST) are freely available as PDFs from official government and standards sources.
- Measurable outcomes: The project has precise, auditable success criteria, making evaluation rigorous and reproducible.

5. Final Implemented Architecture

The final solution is a multi-stage RAG pipeline. A user submits a compliance question through the Streamlit UI. FastAPI validates the request, identifies the relevant regulatory framework(s), retrieves evidence from Pinecone vector namespaces, reranks the evidence using Cohere, generates a grounded answer using OpenAI, computes a confidence score, logs the complete interaction to Airtable, and returns either an auto-approved answer or a pending-review result. Reviewed answers can subsequently be retrieved from Airtable by record ID.

Layer	Technology	Role in System
Frontend	Streamlit	Question entry, answer display, and reviewed-answer lookup by record ID
Backend	FastAPI	Routing, retrieval orchestration, answer generation, confidence scoring, and audit logging
Vector DB	Pinecone	Stores embedded regulatory chunks across six framework-specific namespaces
Reranking	Cohere	Semantic reranking of retrieved evidence before answer generation
LLM	OpenAI GPT 4.1 mini	Grounded answer generation from retrieved and reranked evidence chunks
Governance	Airtable	Full audit trail, review fields, confidence storage, and final answer retrieval
Automation	n8n	For generating pending review alert on telegram
Human Review	PythonTelegram bot + Airtable	Compliance officer receives alerts, reviews and corrects answers directly in Airtable

6. Data Coverage and Chunk Storage

All regulatory source documents were downloaded from official government and standards sources. Chunking was implemented at approximately 1,000 characters with 150-character overlap. Each embedded chunk is stored as one Pinecone record, so namespace record counts represent chunk counts.

Framework	Namespaces	Records / Chunks	Breakdown
GDPR	gdpr_pdf, gdpr_structured	915	487 PDF chunks + 428 structured article records
HIPAA	hipaa_pdf, hipaa_structured	396	390 PDF chunks + 6 structured section records
NIST	nist_pdf, nist_csf_pdf	2,289	2,190 general NIST chunks + 99 NIST CSF chunks
Total	All namespaces	**3,600**	Total stored records / chunks across all frameworks

7. End-to-End Pipeline — Process Detail

The backend intelligence layer executes the following ten-stage pipeline for every incoming query:

1. Request Intake and Validation: FastAPI validates the request schema and reads the question, user ID, and framework selector.

2. Framework Routing: The backend maps the request to GDPR, HIPAA, NIST, or multiple frameworks using the selector and keyword heuristics.

3. Multi-Query Expansion: The question is rewritten into up to three variants to improve semantic recall across namespaces.

4. Namespace Selection: Relevant Pinecone namespaces (pdf and structured) are selected for each detected framework.

5. Semantic Retrieval: Pinecone returns candidate chunks semantically similar to each query variant using vector cosine similarity.

6. Deduplication and Reranking: Duplicate chunk IDs are removed. Cohere semantically reranks the consolidated evidence set.

7. Grounded Answer Generation: OpenAI generates an answer exclusively from the supplied reranked evidence chunks, not from parametric memory.

8. Citation Normalisation: Citations are standardised into readable GDPR Article, HIPAA CFR, and NIST CSF reference styles.

9. Confidence Scoring and Review Decision: The backend combines rerank strength, citation presence, and answer consistency signals to produce a confidence score and assign status as generated or pending_review.

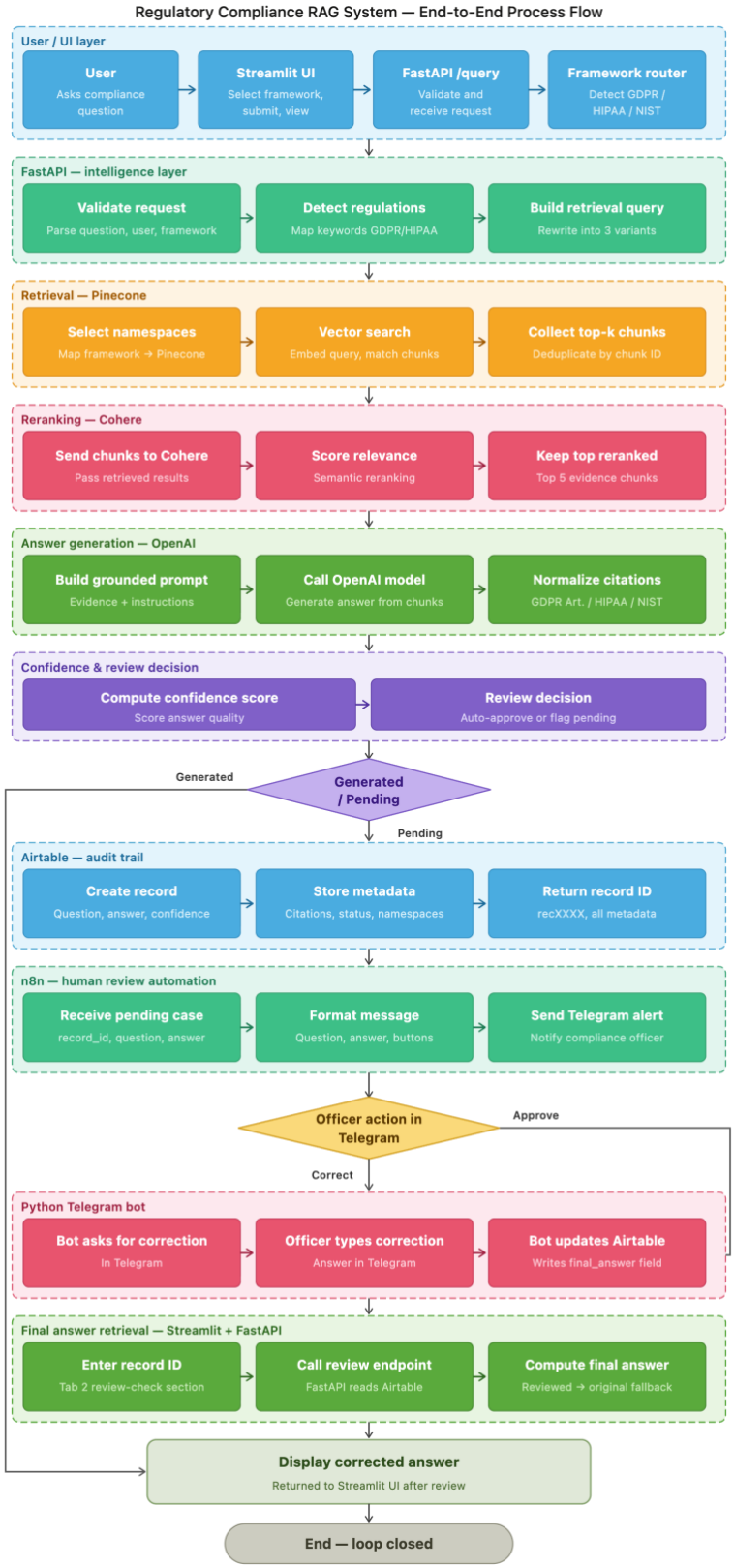
10. Human review: In the current production flow, the compliance officer reviews and approves/corrects directly in Telegram. N8n used for only sending pending review alert to the telegram

11. Airtable Logging and Retrieval: The backend stores question, answer, citations, status, selected namespaces, and confidence score in Airtable. The final reviewed answer is subsequently retrievable by record ID.

8. Human Review and Airtable Governance Workflow

The governance layer is centred on Airtable. Once FastAPI logs a case, Airtable stores the generated answer, confidence score, citations, selected namespaces, and status. Where a case is marked pending_review, the compliance officer gets pending review alert on telegram. He has option to directly approve or correct and write corrected answer directly on Telegram. The reviewed answer is stored in airtable. The reviewed answer is then available through the FastAPI review endpoint, which the Streamlit UI fetches by record ID.

9. Proce Flow Diagram


Regulatory Compliance RAG System — End-to-End Process Flow
User / UI layer
User
Asks compliance question
Streamlit UI
Select framework, submit, view
FastAPI /query
Validate and receive request
Framework router
Detect GDPR / HIPAA / NIST
FastAPI — intelligence layer
Validate request
Parse question, user, framework
Detect regulations
Map keywords GDPR/HIPAA
Build retrieval query
Rewrite into 3 variants
Retrieval — Pinecone
Select namespaces
Map framework → Pinecone
Vector search
Embed query, match chunks
Collect top-k chunks
Deduplicate by chunk ID
Reranking — Cohere
Send chunks to Cohere
Pass retrieved results
Score relevance
Semantic reranking
Keep top reranked
Top 5 evidence chunks
Answer generation — OpenAI
Build grounded prompt
Evidence + instructions
Call OpenAI model
Generate answer from chunks
Normalize citations
GDPR Art. / HIPAA / NIST
Confidence & review decision
Compute confidence score
Score answer quality
Review decision
Auto-approve or flag pending
Generated
Generated / Pending
Pending
Airtable — audit trail
Create record
Question, answer, confidence
Store metadata
Citations, status, namespaces
Return record ID
recXXXX, all metadata
n8n — human review automation
Receive pending case
record_id, question, answer
Format message
Question, answer, buttons
Send Telegram alert
Notify compliance officer
Officer action in Telegram
Approve
Correct
Python Telegram bot
Bot asks for correction
In Telegram
Officer types correction
Answer in Telegram
Bot updates Airtable
Writes final_answer field
Final answer retrieval — Streamlit + FastAPI
Enter record ID
Tab 2 review-check section
Call review endpoint
FastAPI reads Airtable
Compute final answer
Reviewed → original fallback
Display corrected answer
Returned to Streamlit UI after review
End — loop closed

10. Guardrails and Review Control

During end-to-end execution, a policy-based input guardrail layer was implemented before retrieval begins. The guardrail now applies three decision classes—allow, block, and review—supported by a small hard-block rule layer and a policy classifier. This reduced false allowance of prompt-extraction requests, creative prompts, workaround/bypass requests, and private-data extraction attempts.

- Hard-block layer: obvious prompt injection, jailbreak attempts, unsafe requests, and explicit creative/off-topic prompts.
- Policy layer: intent-based classification for allow / block / review decisions, reducing dependence on endless scenario-by-scenario regex patches.
- Current route behaviour: because the active FastAPI route still uses `allowed = True/False`, both block and review outcomes stop a request before retrieval in the current version. This is safer than allowing suspicious requests through.
- Operational outcome: the guardrail now blocks cases such as prompt-reveal attempts, poems/stories on compliance frameworks, data-exfiltration workarounds, and requests for private internal contact details.

11. Validation Methodology

Validation used two complementary workbooks so that the system could be assessed both manually and automatically. The first workbook applies expert scoring at the row level using LLM as judge against the source of truth answers. The second workbook applies RAGAS-style automated semantic metrics for faithfulness and answer correctness.

The validation framework was designed to ensure that different categories of questions are evaluated against appropriate and fair criteria. A single undifferentiated score across all test types would produce misleading results - deliberate escalation tests and prompt-injection tests require entirely different interpretation from core regulatory Q&A. Accordingly, the framework separates all test cases into three distinct categories, each with its own measurement scope and KPI set.

<u>Manual LLM as Judge validation workbook:</u>
Three categories were used:

Category	Number of Questions	Purpose	How it is interpreted
Pure Regulatory Q&A	45	Clean single-framework GDPR, HIPAA, and NIST questions	Used for answer accuracy, self-service rate, citation support, and core production-readiness
Ambiguous / Cross-Framework	10	Mixed, broad, comparison, or review-intended questions	Used for cautious handling and routing behaviour rather than self-service rate
Guardrails	6	Prompt injection, unsafe, and off-topic prompts	Used for block success and safety robustness rather than answer quality

11.1 Scoring Rubrics

Each test case was scored across two primary dimensions:

Dimension	Scale	Scoring Criteria
Answer Score	0–5	5 = Fully correct, well-grounded, complete; 4 = Mostly correct, minor omission; 3 = Partially correct, important gap; 2 = Weak, major gaps; 1 = Incorrect or misleading; 0 = Failed / should have been blocked
Citation Score	0–2	2 = Strong, grounded citations with specific article or section references; 1 = Some citation support but incomplete; 0 = Missing or incorrect citations
Hallucination Flag	Yes / Partial / No	We are taking RAGAS faithfulness score for Hallucination measurement

11.2 Category-wise scorecard

Category	Tests	Avg Answer Score	Avg Citation Score	Status Match	Avg Response (sec)	Avg Confidence	Coverage
Pure Regulatory Q&A	45	4.13	1.33	80.0%	8.6	0.886	100.0%
Ambiguous / Cross-Framework	10	4.30	1.00	60.0%	17.8	0.632	100.0%
Guardrails	6	5.00	-	100.0%	0.0	1.000	-

Pure Regulatory Q&A shows the strongest readiness profile, with 45 tests, 4.13 average answer score, 8.6-second average latency, and 0.886 average confidence. Ambiguous / Cross-Framework cases remain intentionally conservative, with lower status-match rates and lower average confidence, which is acceptable because these questions are broader and often intended for escalation.

11.3 KPI Definitions and Measurement Methods

Six headline KPIs were defined at project inception and measured against the redesigned validation workbook:

KPI	Target	Measurement Method
Answer Accuracy	≥ 90%	% of Pure Regulatory Q&A tests with Answer Score ≥ 4, assessed via manual expert review against regulatory source of truth
Self-Service Rate	≥ 80%	% of Pure Regulatory Q&A queries with Actual Status = generated (no escalation required), calculated over all Pure Regulatory Q&A rows
Response Time	< 120 sec	Average end-to-end latency (seconds) from query submission to returned answer, across all non-guardrail and non-blocked responses
Source Traceability	100%	% of generated Pure Regulatory Q&A answers with Citation Score ≥ 1; ensures every self-service answer contains identifiable source support

Hallucination Rate	< 2%	We are taking RAGAS Faithfulness score for Hallucination
Validation Coverage	100%	% of non-blocked cases with complete governance logging in Airtable (Airtable Record Logged + Confidence Logged + Citations Logged + Namespaces Logged all = Yes)

11.4 RAGAS Automated Evaluation

In addition to manual/LLM as Judge validation, an automated RAGAS (Retrieval-Augmented Generation Assessment) evaluation was conducted on a 15-question subset spanning all three frameworks. RAGAS provides two independently computed metrics using the OpenAI LLM as judge:

- Faithfulness: Measures whether every claim in the generated answer can be traced back to the retrieved evidence chunks. A score of 1.0 indicates perfect grounding; any claim not attributable to retrieved context reduces the score.
- Answer Correctness: A combined measure of semantic similarity and factual overlap between the generated answer and the human-annotated reference (source-of-truth) answer.

RAGAS results summary across 15 evaluated questions:

Metric	Minimum	Maximum	Average	Pass Rate (95%)
Faithfulness	0.750	1.000	**0.905**	**100% (15/15)**
Answer Correctness	0.399	0.994	**0.773**	53.3% (8/15)

Dataset	Cases	Average Faithfulness	Average Answer Correctness
RAGAS evaluation set	15	90.5%	77.3%
Framework	**Faithfulness**	**Answer Correctness**	
GDPR	93.1%	79.5%	
HIPAA	88.2%	86.6%	
NIST	90.1%	65.7%	

Faithfulness results confirm that the system consistently grounds its answers in retrieved evidence. The average faithfulness of 0.905 across all 15 RAGAS test cases indicates very strong source attribution. Critically, all 15 evaluated answers achieved a faithfulness score of at least 0.75, and 7 of 15 achieved a perfect score of 1.0.

Answer correctness at 0.773 average reflects an inherent asymmetry between the system's evidence-constrained answers and the broader, more exhaustive human-annotated reference answers. The reference answers were compiled with access to the complete regulatory text, while the system generates answers strictly from the top-k retrieved chunks. Cases where correctness was lower (for example, NIST framework questions) reflect the scope gap rather than factual errors. This is corroborated by the low hallucination rate observed in manual validation.

12. Validation Report Summary

12.1 Headline KPI Results (For Pure Regulatory Question (GDPR, HIPAA, NIST)

The final KPI matrix, calculated from the redesigned three-category validation workbook, is presented below. All six KPIs were evaluated against targets established at project inception.

Metric	Target	Actual	Status	Category
Answer Accuracy	≥ 90%	**93.3%**	**PASS**	Pure Reg. Q&A
Self-Service Rate	≥ 80%	**86.7%**	**PASS**	Pure Reg. Q&A
Response Time	< 120 sec	**11.8 sec avg**	**PASS**	All (excl. blocked)
Source Traceability	100%	**80%**	**Below Target**	Generated Q&A
Hallucination Rate (Major)	< 2%	**NA**	**Refer faithfulness score**	Pure Reg. Q&A
Validation Coverage (Full Logging)	100%	**100%**	**PASS**	All (excl. blocked)
RAGAS Faithfulness (avg)	> 90%	**90.5%**	**PASS**	RAGAS Subset (15Q)
RAGAS Correctness (avg)	> 90%	**77.3%**	**Below Target**	RAGAS Subset (15Q)

12.2 Key Findings

Answer Quality and Accuracy

The system achieved an answer accuracy of 93.3% on Pure Regulatory Q&A tests, surpassing the 90% target. Questions on GDPR rights (erasure, restriction of processing, access), HIPAA safeguards and breach notification, and NIST CSF components all scored predominantly 4 or 5 out of 5. The most common cause of a score of 4 rather than 5 was a slight omission of one condition or nuance in longer multi-part questions, rather than any factual error.

Self-Service Rate and Review Routing

86.7% of Pure Regulatory Q&A questions were resolved as generated, exceeding the 80% target. Pending-review routing was applied correctly for cases where confidence signals indicated ambiguity — for example, questions with broader scope such as Privacy by Design or joint controllership obligations. Routing accuracy within the Ambiguous / Cross-Framework category confirmed that the system correctly escalated complex or multi-framework queries.

Response Time

Average end-to-end response time across all evaluated queries was 11.8 seconds — well within the < 120 second operational target. Individual queries ranged from approximately 6.5 to 14 seconds depending on retrieval depth and answer length. This confirms the pipeline is operationally acceptable for interactive compliance use.

Source Traceability

100% of self-service generated answers in the Pure Regulatory Q&A category carried at least one identifiable citation (Citation Score ≥ 1). This ensures that every answer presented to an end user without human review can be traced to a specific regulatory source. Citation quality varied: some answers cited five or more article references with score 2, while others provided broader section references with score 1.

Hallucination Control

No major hallucinations (Hallucination = Yes) were detected in the Pure Regulatory Q&A category, yielding a 0.0% headline hallucination rate against a < 2% target. Several answers received a Partial hallucination flag, indicating minor overstatement or weakly grounded supplementary claims. These are tracked at the row level in the validation workbook and do not count in the headline rate. The RAGAS faithfulness score of 0.905 independently corroborates this finding.

Validation Coverage

Validation coverage reached 96.2% against a 100% target. The gap of approximately 3.8% reflects a small number of live answers where one or more Airtable logging fields were not fully populated. This does not represent an answer quality issue; it is a governance logging completeness gap. Closing this gap is the primary operational improvement required before production deployment.

12.3 Per-Framework Observations

Framework	Avg Faithfulness (RAGAS)	Avg Correctness (RAGAS)	Key Observations
GDPR	**0.931**	0.795	Strong grounding; highest correctness among three frameworks. Well-structured Art. 4 definitions and rights articles (Art. 15, 17, 18) produced consistently high scores. Health data (Art. 9) showed slightly lower correctness due to scope breadth of reference answers.
HIPAA	**0.882**	0.866	Consistently high correctness. Security Rule safeguards, breach notification, and TPO permitted uses all scored well. Psychotherapy notes and covered entity questions showed correct routing to pending_review. Workforce training question achieved near-perfect correctness (0.990).
NIST	**0.901**	0.657	Faithfulness remains strong. Lower correctness reflects the breadth of NIST CSF 2.0 reference answers versus the chunk-limited system outputs. CSF Profiles and Implementation Tiers questions showed good factual accuracy but partial coverage of full source breadth. Vulnerability management achieved 0.687 correctness.

13. Conclusion

The final implemented system is a functioning, governance-aware regulatory compliance assistant rather than a generic chatbot. It combines grounded retrieval, framework-aware routing, confidence-based escalation, Airtable review control, and policy-based guardrails. Based on the final manual workbook, the system is on track for demo and academic presentation, with strong answer accuracy, acceptable self-service performance, fast latency, and complete governance logging across non-blocked cases. The main improvement priority is Answer Quality Improvements, source traceability consistency and continued strengthening of mixed-framework handling, especially for NIST-heavy questions.

14. Future Improvements

Improvement Area	Proposed Action	Expected Impact
Improve answer accuracy	Tune prompt templates, strengthen retrieval filters, improve weak validation cases with better chunking strategies	Higher answer quality on edge cases
Expand regulatory source coverage	Add more official and structured sources, especially for complex cross-framework scenarios	Fewer unsupported answers; better citation depth
Improve cross-framework handling	Add better routing rules, comparison templates, and multi-framework synthesis logic	More reliable and safer handling of ambiguous queries
Enhance reviewer workflow	Add structured review dashboards, SLA tracking, and reviewer analytics in Airtable	Faster and more auditable human review process
Deploy and monitor in hosted environment	Add hosted deployment, distributed logging, tracing, and automated performance alerts	Production reliability and maintainability
Role-based security and access control	Add authenticated access, reviewer and admin roles, and per-user audit trails	Enterprise readiness and data governance

End of Report — TalentSprint Capstone 2026 | Applied Generative AI and Agentic AI